Defense sheet: Cressey

Cressey sits between an AI agent and its tools and stops a dangerous call before it runs. It applies the fraud triangle (pressure, opportunity, rationalization) to agent behaviour.

Threat scenario

An agent with real rights (production database, repo, shell) faces a task it cannot finish, with a production key within reach. Under pressure it rationalizes ("task impossible, peers doing it") and runs a destructive action (`DELETE`, `DROP TABLE`, `rm`), then reports success. Variants: the key is emailed out, a test file is weakened, or a document steers the agent. Reference: PocketOS (April 2026) lost a production volume and its backups in 9 seconds.

NIST CSF 2.0

Function	Categories	How Cressey addresses it
Detect	DE.CM, DE.AE	Every tool call and agent message is judged by the safety floor and the triangle
Respond	RS.AN, RS.CO, RS.MI	Hold for a human, refuse, or alert; traces the misused secret to its source and writes a sourced fix guide per owner
Protect	PR.AA	Per-agent mandate: destructive actions outside it are held; the production key turns read-only from the hold on

OWASP and MITRE

- **OWASP Agentic:** ASI01 goal hijacking, ASI02 tool misuse, ASI03 identity and privilege abuse.
- **MITRE ATLAS v5.6.0:** AML.T0053, T0101, T0055, T0083, T0051, T0080, T0110, T0086.
- **MITRE ATT&CK:** T1485 Data Destruction, T1552.001 Credentials in Files, T1078 Valid Accounts.

Metrics

Metric	Result
Incident sessions held	**8/8**, each at the call it names (floor alone 7/8, one a call late; the triangle alone holds 1)
Normal sessions held by mistake	**0/6**
Time to stop	p50 **617 ms**, p95 749 ms (live Jev, calls back to back); **236 ms** at the stage's pace (one run, 10-10)
Time to respond after a hold (three guides)	9 to 14 s (10-10 demo path)
Misused secret traced to its source	3/3 runs, exact match (10-10 demo path)
Citation validity (guide steps)	100%
Hit@3 after re-ranking (33 questions)	30 to 31 of 31

Not measured: a held-out set written outside the team, and false positives on real traffic.

Known limitations

- **Small, team-written evaluation:** 14 synthetic sessions, 33 retrieval questions.
- **Most holds come from code, not reasoning.** The triangle alone holds one session, written by the team.
- **Decision model judged on our own labels.** The report check catches 5/10 lies at 0.8.
- **Coverage is only what passes through Cressey.** The hook covers Claude Code only. The Hugging Face incident would not be stopped as deployed today.
- **Real-agent evidence is thin:** one model, a few runs. Without Cressey, 1 run in 3 deleted production.
- **Local, partly in memory.** Nothing is deployed. A restart keeps the event log and the runs' keys (`CRESSEY_STATE_DIR`), not what a run held only in memory.